

Role řízení kybernetické bezpečnosti

Václav Stupka
PV017 Bezpečnost IT

Osnova přednášky

Proč řízení kybernetické bezpečnosti

od regulace k praxi

Compliance a regulace

jak řízení pomáhá souladu

Jak řízení funguje

PDCA, rizika, rozsah, rámce

Procesy

co musí v organizaci běžet

Vnitřní předpisy

hierarchie a závaznost

Role

kdo za co odpovídá

Proč řízení kybernetické bezpečnosti

Regulace říká CO, řízení říká JAK



„Zákon nepředepisuje konkrétní firewall. Vyžaduje, aby organizace věděla, proč má která opatření, kdo za ně odpovídá – a uměla to doložit.“

Tři úrovně: řízení, správa, provoz

Governance – řízení

Směr, odpovědnost, dohled, apetit k riziku

Kdo:

Vrcholné vedení, výbor pro řízení KB

Management – správa

Plánování, zavádění, měření, zlepšování

Kdo:

Manažer KB / CISO, architekt KB

Operations – provoz

Každodenní výkon opatření, monitoring, reakce

Kdo:

IT provoz, SOC, garanti aktiv, uživatelé

Viz ISO/IEC 27014 (governance informační bezpečnosti) a NIST CSF 2.0 – nová funkce GOVERN (2024)

Bezpečnost není jen technologie



Technologie bez procesu je nespravovaná. **Proces bez lidí** je jen papír. **Lidé bez nástrojů** nestíhají.

Compliance a regulace

Co je compliance

Compliance = schopnost organizace prokazatelně dodržovat povinnosti, které se na ni vztahují – a doložit to.

Právní povinnosti

- Zákon č. 264/2025 Sb. (ZoKB) a vyhlášky
- NIS2, DORA, CRA
- GDPR čl. 32 – zabezpečení zpracování
- Sektorová regulace

Smluvní povinnosti

- Požadavky zákazníků a partnerů
- Podmínky kybernetického pojištění
- SLA a bezpečnostní přílohy smluv

Dobrovolně převzaté

- ISO/IEC 27001 – certifikace
- Kodexy a oborové standardy
- Vlastní politiky a směrnice
- Veřejné závazky organizace

Od regulace ke compliance



↻ Cyklus se opakuje – mění se regulace, organizace i hrozby

Nový ZoKB vtahuje řízení přímo do zákona

Zákon č. 264/2025 Sb.

- Stanovit rozsah řízení KB
- Zavádět bezpečnostní opatření
- Hlásit kybernetické incidenty
- Zavádět protiopatření NÚKIB
- Promítnout požadavky do smluv s dodavateli

Vyhl. 409/2025 Sb. – vyšší režim

- § 3 systém řízení bezpečnosti informací
- § 4 povinnosti vrcholného vedení, výbor pro řízení KB
- § 5 bezpečnostní role
- § 6 bezpečnostní politika a dokumentace
- Řízení rizik, dodavatelů, incidentů...

Vyhl. 410/2025 Sb. – nižší režim

- Vedení určí osobu pověřenou KB a svěří jí pravomoci
- Prokazatelné školení vedení
- Zajištění zdrojů, přehled o plnění opatření
- Bezpečnostní politika a dokumentace, pravidelný přezkum

Odpovědnost nese vedení

§

NIS2 čl. 20

Řídící orgány schvalují opatření k řízení rizik, dohlíží na ně, odpovídají za porušení a musí se školit

§

NIS2 čl. 32 odst. 5

U základních subjektů: možnost dočasného zákazu výkonu řídicí funkce

§

DORA čl. 5

Řídící orgán nese konečnou odpovědnost za řízení ICT rizik finanční entity

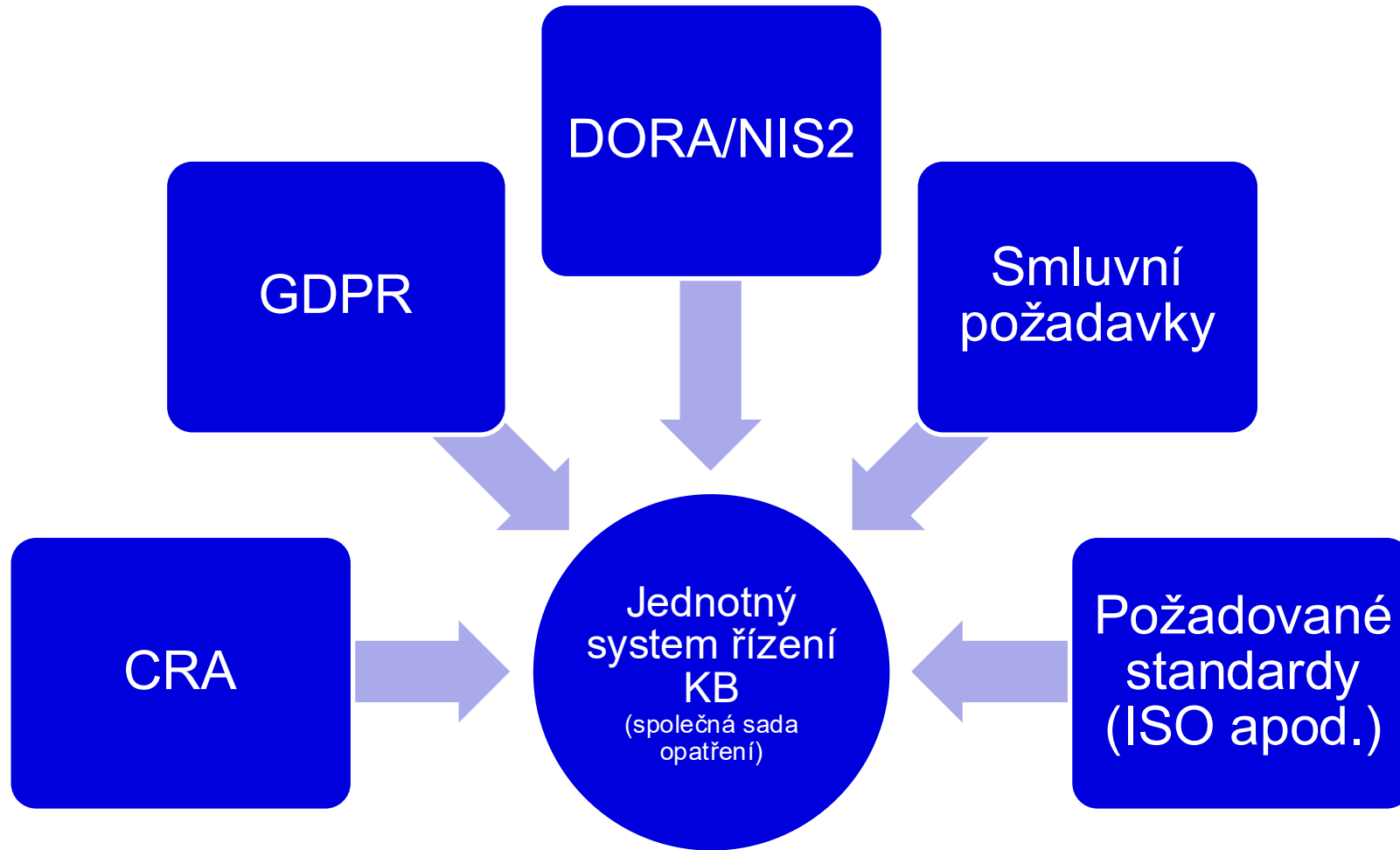
§

OZ § 159, ZOK § 51

Péče řádného hospodáře; ochrana jen při informovaném rozhodnutí v dobré víře

Důsledek: vedení nemůže kyberbezpečnost „delegovat a zapomenout“ – potřebuje řízení, které mu dodá informace pro rozhodnutí.

Jeden systém řízení, mnoho regulací



Compliance vs. bezpečnost

Compliance bez řízení

- „Papírová bezpečnost“ – dokumenty pro kontrolu
- Jednorázový projekt před auditem
- Opatření bez vazby na rizika
- Nikdo neví, zda opatření fungují
- Odpovědnost rozmazaná

Compliance skrze řízení

- Dokumenty popisují skutečný stav
- Kontinuální proces (PDCA)
- Opatření odvozená z analýzy rizik
- Účinnost se měří a vyhodnocuje
- Jasní vlastníci a role

Compliance je minimum, ne cíl. Řízení z ní dělá vedlejší produkt dobré bezpečnosti.

Jak řízení funguje

Cyklus neustálého zlepšování (PDCA)



Vazba na ISO/IEC 27001:2022

Plan	ISO/IEC 27001 kap. 4–6
Do	kap. 7–8
Check	kap. 9
Act	kap. 10

Nejčastěji se šetří na CHECK a ACT – a právě tam vzniká papírová bezpečnost.

Rozsah řízení (scope)



- 1 Identifikuj primární aktiva celé organizace
- 2 Urči ta, která souvisejí s regulovanou službou
- 3 Urči související organizační části a podpůrná aktiva
- 4 Tím je dán rozsah – dokud není určen, platí pro celou organizaci

Rámce a standardy pro řízení KB

Rámec	Zaměření	Typické využití
ISO/IEC 27001 / 27002	Systém řízení bezpečnosti informací, katalog opatření	Certifikace, základ ISMS
NIST CSF 2.0	Govern · Identify · Protect · Detect · Respond · Recover	Strategie, komunikace s vedením
CIS Controls v8	Prioritizovaná technická opatření	Praktický start, menší organizace
COBIT 2019	Governance a řízení podnikového IT	Audit IT, vazba na řízení podniku
IEC 62443	Bezpečnost průmyslových řídicích systémů	OT, výroba, energetika
ISO 22301	Řízení kontinuity činností	BCM, odolnost služeb

Podrobněji: ISMS (20. 10.), standardy a Common Criteria (27. 10.)

Procesy řízení kybernetické bezpečnosti

Klíčové procesy řízení KB



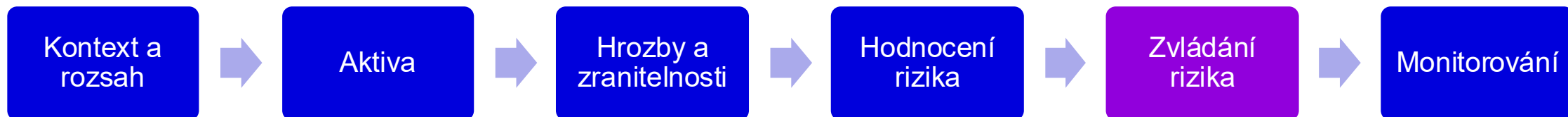
Řídicí

Ochranné

Reakce a obnova

Každý proces: vlastník · předpis · záznamy · metrika

Řízení rizik jako motor řízení KB



Strategie zvládání rizik



Kdo rozhoduje?

Analýzu připravuje manažer KB s garanty aktiv. O přijatelnosti zbytkových rizik prokazatelně rozhoduje vedení.

Výstupy: registr aktiv, registr rizik, plán zvládání rizik, prohlášení o aplikovatelnosti

Řízení dodavatelů

Výběr	Smlouva	Provoz	Ukončení
• Bezpečnostní požadavky v zadání • Hodnocení rizika dodavatele • Certifikace (ISO 27001, EUCC)	• Bezpečnostní příloha • Hlášení incidentů dodavatelem • Právo auditu, sankce	• Monitoring plnění a SLA • Řízení přístupů dodavatele • Pravidelné přehodnocení	• Exit strategie • Vrácení a výmaz dat • Odebrání přístupů

Pozor: vnitřní předpis dodavatele nezavazuje. Co není ve smlouvě, nelze vymáhat.

Měření, audit a přezkoumání

Metriky

- % systémů s aktuálními záplatami
- Průměrná doba detekce a reakce
- Míra prokliku při phishingové simulaci
- % účtů s vícefaktorovou autentizací

Audit

- Interní audit KB – nezávislost
- Externí certifikační audit
- Kontrola NÚKIB
- Penetrační testy a cvičení

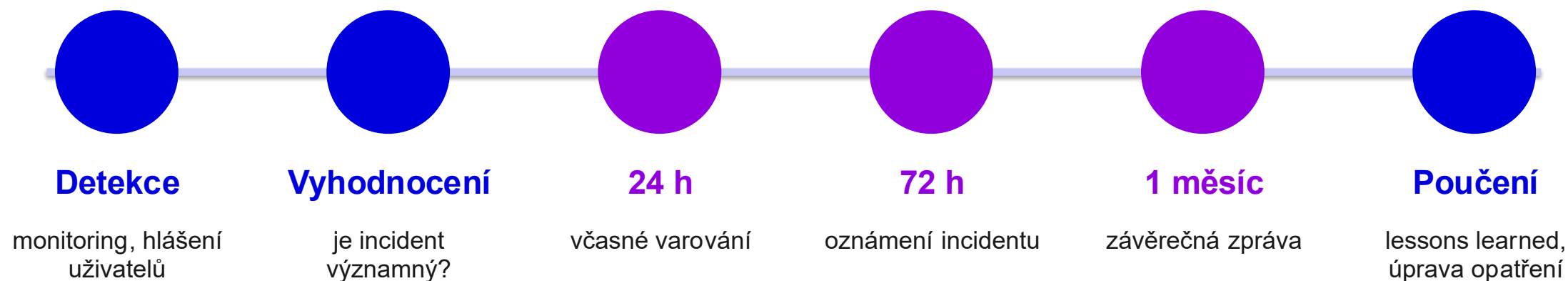
Přezkoumání vedením

- Minimálně jednou ročně
- Výbor pro řízení KB
- Rozhodnutí o zdrojích a rizicích
- Nápravná opatření

Co se neměří, to se neřídí – a nelze to ani doložit.

Řízení incidentů a hlášení

Lhůty NIS2 čl. 23 (transponováno do ZoKB)



Řízení musí předem určit

- Kdo vyhodnocuje a kdo rozhoduje o hlášení
- Kontakty na NÚKIB / CSIRT a zastupitelnost

Souběh povinností

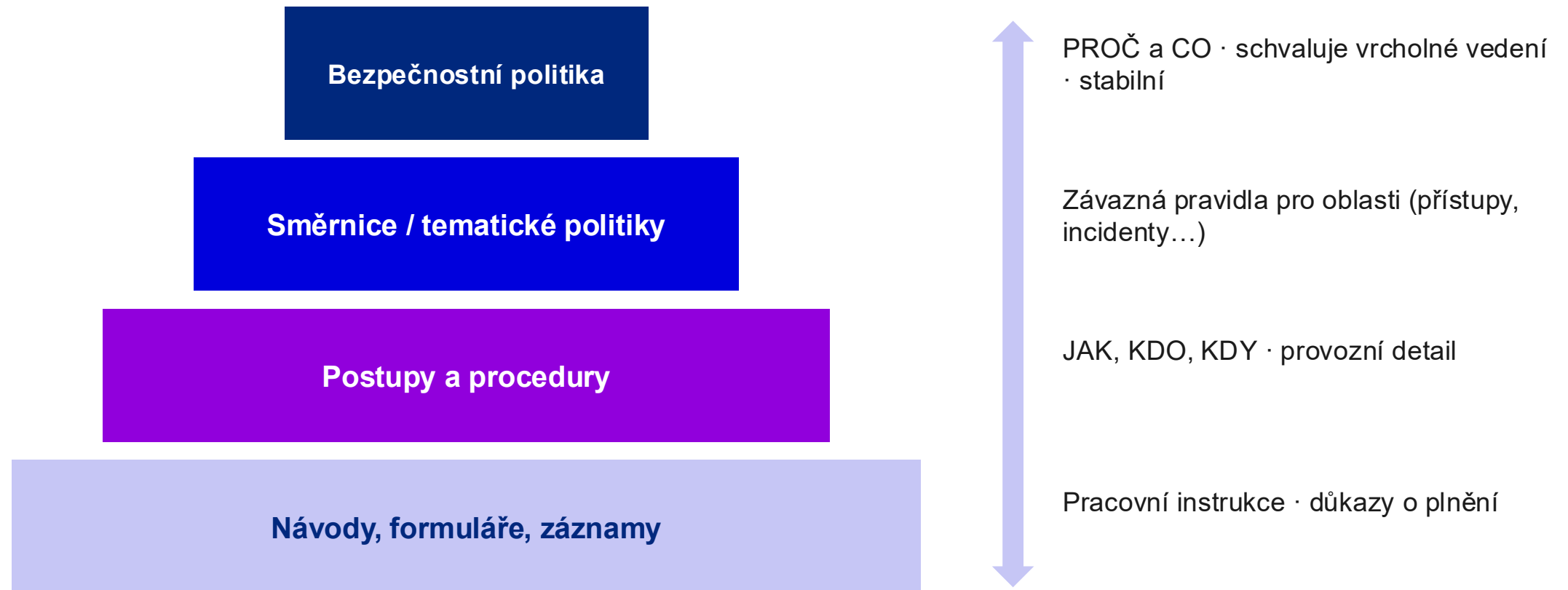
- GDPR čl. 33 – 72 h ÚOOÚ (osobní údaje)
- DORA, sektorové předpisy, smluvní povinnosti

Vnitřní předpisy

Proč vnitřní předpisy



Hierarchie bezpečnostní dokumentace



Čím níže, tím detailnější, častěji měněné a schvalované na nižší úrovni

Typická bezpečnostní dokumentace

Řídicí dokumenty

- Bezpečnostní politika (politika ISMS)
- Metodika řízení rizik
- Registr aktiv a registr rizik
- Prohlášení o aplikovatelnosti (SoA)
- Plán zvládání rizik
- Plán vzdělávání a rozvoje bezpečnostního povědomí

Tematické politiky a směrnice

- Řízení přístupu a identit
- Klasifikace a ochrana informací
- Přijatelné užívání (AUP)
- Řízení incidentů a kontinuita (BCP/DRP)
- Řízení změn, zálohování, kryptografie
- Řízení dodavatelů, bezpečný vývoj

Závaznost vnitřních předpisů: zaměstnanci

§ 305 zákoníku práce

- Závazný pro zaměstnavatele i všechny zaměstnance
- Písemně, bez zpětné účinnosti
- Nesmí být v rozporu s právními předpisy
- Seznámení do 15 dnů, musí být přístupný
- Uchovává se 10 let

§ 301 zákoníku práce

- Zaměstnanec plní pokyny nadřízených
- Dodržuje předpisy vztahující se k vykonávané práci...
- ... pokud s nimi byl **řádně seznámen**

Klíčové je prokazatelné seznámení: podpis, potvrzení v e-learningu, evidence verzí. Vyhláška 409/2025 Sb. vyžaduje jeho strukturované potvrzení.

Závaznost: vůči komu a čím se vynucuje

Zaměstnanci

Základ: Pracovní povinnost (§ 301 ZP)

Vynucení: Výtka · výpověď § 52 písm. g) · okamžité zrušení § 55 · náhrada škody

Vedení a statutáři

Základ: Péče řádného hospodáře, NIS2 čl. 20

Vynucení: Odpovědnost vůči společnosti, sankce regulátora

Dodavatelé

Základ: Nezavazuje! Jen přes smlouvu

Vynucení: Smluvní pokuty, odstoupení, náhrada škody

Externisté a uživatelé

Základ: Smlouva, NDA, podmínky užívání

Vynucení: Smluvní sankce, odebrání přístupu

Aby předpis skutečně platil



Schválen oprávněnou osobou (politiku schvaluje vedení)



Prokazatelně seznámeni všichni dotčení



Srozumitelný a v praxi proveditelný



V souladu se zákonem (např. monitoring – § 316 ZP, GDPR)



Aktuální: přezkum min. 1× ročně, verzování

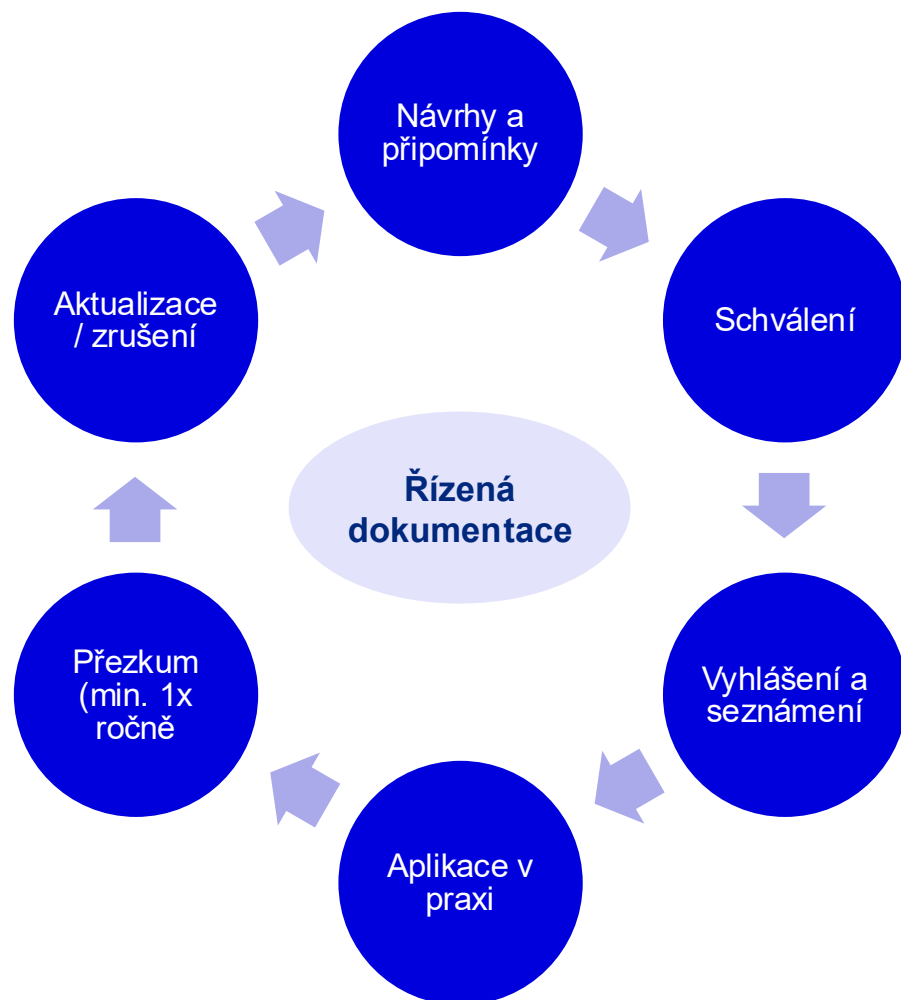


Kontrolován a vymáhán

Nevymáhaný předpis je horší než žádný

dává signál, že pravidla neplatí, a oslabuje pozici organizace při sporu i kontrole

Životní cyklus vnitřního předpisu

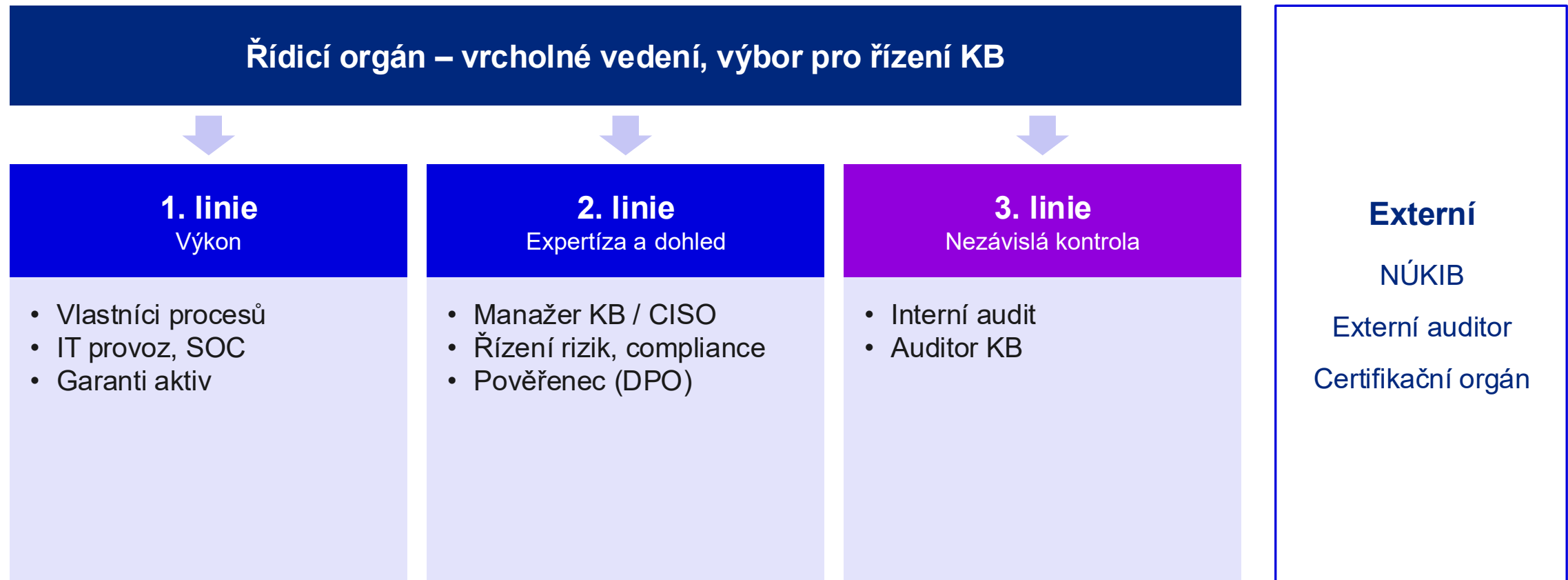


Spouštěče mimořádného přezkumu

- Nová nebo změněná regulace
- Závažný incident
- Výsledek auditu či kontroly
- Reorganizace, nový systém nebo dodavatel
- Změna hrozeb (varování NÚKIB)

Role v řízení kybernetické bezpečnosti

Model tří linií



Zdroj: The IIA's Three Lines Model (2020)

Bezpečnostní role (vyhl. 409/2025 Sb.)

Vrcholné vedení	Výbor pro řízení KB	Manažer KB
Schvaluje politiku, zajišťuje zdroje, rozhoduje o rizicích, určuje role	Koordinace a dohled; člen vedení + manažer KB; min. 1× ročně	Řídí a rozvíjí systém řízení bezpečnosti; hlavní kontaktní osoba
Architekt KB	Garant aktiva	Auditor KB
Navrhuje bezpečnostní architekturu a technická opatření	Odpovídá za konkrétní aktivum – jeho rozvoj, užívání a bezpečnost	Nezávisle ověřuje soulad a účinnost; nesmí auditovat sám sebe

Nižší režim (vyhl. 410/2025 Sb.): vedení určí osobu pověřenou kybernetickou bezpečností a svěří jí potřebné pravomoci

Kyberbezpečnost není jen věcí bezpečáků

1

IT provoz a SOC

Provoz opatření, monitoring, reakce na incidenty

2

Pověřenec (DPO)

GDPR čl. 37–39, porušení zabezpečení osobních údajů

3

Personální útvar (HR)

Nástup, změna role, odchod, vzdělávání, disciplinárky

4

Právní a compliance

Výklad povinností, smlouvy, vnitřní předpisy

5

Nákup

Bezpečnostní požadavky na dodavatele

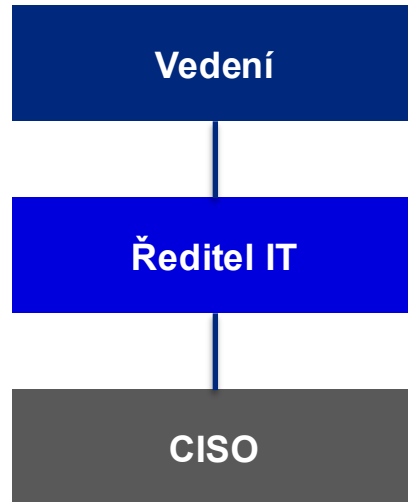
6

Každý zaměstnanec

Dodržuje pravidla a hlásí podezřelé události

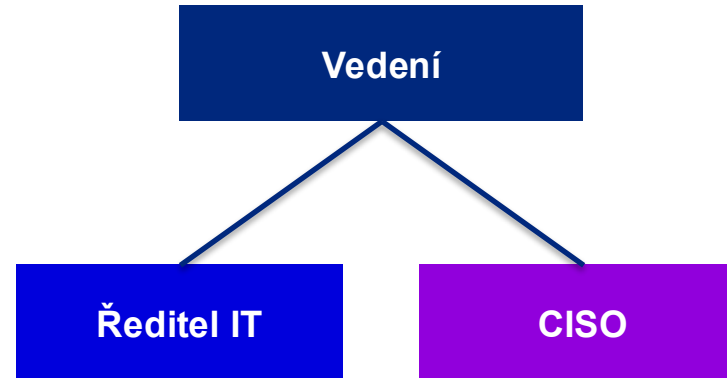
Postavení manažera KB (CISO)

Varianta A – pod IT



Konflikt zájmů: dohlíží na vlastního nadřízeného

Varianta B – pod vedením



Nezávislost a přímý přístup k vedení

Předpoklady úspěchu

- Mandát a přímý přístup k vedení
- Zdroje (rozpočet, lidé)
- Oddělení od správy systémů
- Zastupitelnost
- Odbornost a průběžné vzdělávání

Kdo co dělá: matice RACI

Činnost	Vedení	Manažer KB	IT provoz	Garant aktiva	Auditor KB
Schválení bezpečnostní politiky	A	R	C	C	I
Analýza rizik	I	A/R	C	R	I
Akceptace zbytkového rizika	A/R	C	I	C	I
Zavedení technického opatření	I	A	R	C	I
Rozhodnutí o hlášení incidentu	I	A/R	C	C	I
Audit KB	A	C	C	C	R

R provádí · A odpovídá a schvaluje (vždy jen jeden) · C konzultován · I informován | ilustrativní příklad

Vzdělávání a bezpečnostní kultura

Vedení	Prokazatelné školení o povinnostech a rizicích
Všichni zaměstnanci	Vstupní a pravidelné školení, phishingové simulace
Bezpečnostní role	Odborné vzdělávání, certifikace, cvičení
Administrátoři a vývojáři	Bezpečná správa a bezpečný vývoj

Bezpečnostní kultura

Lidé hlásí chyby a podezřelé události bez strachu z trestu.

Pozdě nahlášený incident je dražší než přiznaná chyba.

Shrnutí

V praxi: od registrace k fungujícímu řízení

Modelová situace: regionální nemocnice – regulovaná služba v režimu vyšších povinností



Kroky 1–5 jsou řídicí – technická opatření přicházejí až v kroku 6.

Shrnutí

Řízení je převodník

mezi regulací, která říká CO, a praxí, která řeší JAK

Odpovědnost má vedení

NIS2, DORA i ZoKB ji výslovně kladou na řídicí orgány

Compliance je minimum

řízení z ní dělá vedlejší produkt skutečné bezpečnosti

Předpis platí, jen když žije

schválení, prokazatelné seznámení, přezkum a vymáhání

Role musí být jasné

kdo provádí, kdo dohlíží, kdo nezávisle ověřuje

Otázky k zamyšlení

- ?
 - ?
 - ?
 - ?
 - ?
- Je možné být plně compliant a přesto nebezpečný? A naopak?
- Kdo by měl v organizaci rozhodovat o akceptaci rizika – a proč ne IT?
- Kam organizačně zařadit CISO a proč?
- Jak zajistit, aby bezpečnostní směrnice nebyla jen „šuplíkový“ dokument?
- Jak prosadit bezpečnostní požadavky vůči dodavateli, který je silnější smluvní stranou?

Díky za pozornost

stupka@muni.cz